

TRƯỜNG ĐẠI HỌC NGOẠI NGỮ - TIN HỌC THÀNH PHỐ HỒ CHÍ MINH

KHOA CÔNG NGHỆ THÔNG TIN



HỌC KỲ 1 2025-2026

KIỂM ĐỊNH CHẤT LƯỢNG PHẦN MỀM

KIỂM THỬ TRANG WEB QUẢN LÝ HOMESTAY

Nhóm sinh viên: 3

Giảng viên hướng dẫn: Thạc Sĩ. Trần Cẩm Tú

Sinh viên thực hiện:

- | | |
|-------------------|------------|
| 1. Đặng Quốc Hưng | 23DH110561 |
| 2. Trần Mỹ Duyên | 23DH110561 |

TP Hồ Chí Minh, tháng 12 năm 2025

MỤC LỤC

MỤC LỤC	i
DANH MỤC HÌNH	3
CHƯƠNG 1: MỞ ĐẦU VÀ TỔNG QUAN DỰ ÁN	4
1.1. Giới thiệu chung	4
1.2. Mục tiêu và Phạm vi dự án	4
CHƯƠNG 2: KẾ HOẠCH KIỂM THỬ	5
2.1. Định danh và Giới thiệu kế hoạch (Identifier & Introduction)	5
2.2. Các đối tượng kiểm thử (Test Items)	5
2.3. Các tính năng không kiểm thử (Features Not To Be Tested)	5
2.4. Chiến lược và Phương pháp kiểm thử (Test Approach/Strategy)	6
2.5. Tiêu chí Đạt/Không đạt (Pass/Fail Criteria)	6
2.6. Môi trường kiểm thử (Environmental Needs)	6
2.7. Phân công trách nhiệm (Roles and Responsibilities)	7
CHƯƠNG 3: CHECKLIST	8
3.1. Rà soát Kiến trúc và Cơ sở dữ liệu	8
3.2. Rà soát Giao diện người dùng (UI Checklist)	8
CHƯƠNG 4: TEST CASES	10
4.1. Module Đăng ký và Đăng nhập	10
4.2. Module Tìm kiếm và Đặt phòng (Client)	10
4.3. Module Quản lý Vận hành (Admin)	11
4.4. Module Báo cáo và Thống kê	12
CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO	13
5.1. Tổng hợp lỗi phát hiện (Defect Report)	13

5.2.	Quản lý rủi ro và Kế hoạch dự phòng (Risks and Contingencies)..	18
KẾT LUẬN		24

DANH MỤC HÌNH

Hình 1. Biểu đồ tròn thể hiện kết quả của Testcases 1 – Đăng nhập	13
Hình 2. Biểu đồ tròn thể hiện kết quả của Testcases 2 – Đăng ký	14
Hình 3. Biểu đồ tròn thể hiện kết quả của Testcases 3 – Đặt phòng.....	14
Hình 4. Biểu đồ tròn thể hiện kết quả của Testcases 4 – Sửa TT cá nhân	15
Hình 5. Biểu đồ tròn thể hiện kết quả của Testcases 5 – Đăng xuất	15
Hình 6. Biểu đồ cột của Testcase 1 thể hiện lỗi theo Mức độ nghiêm trọng ...	16
Hình 7 Biểu đồ cột của Testcase 2 thể hiện lỗi theo Mức độ nghiêm trọng	16
Hình 8. Biểu đồ cột của Testcase 3 thể hiện lỗi theo Mức độ nghiêm trọng ...	17
Hình 9. Biểu đồ cột của Testcase 4 thể hiện lỗi theo Mức độ nghiêm trọng ...	17
Hình 10. Biểu đồ cột của Testcase 5 thể hiện lỗi theo Mức độ nghiêm trọng .	18

CHƯƠNG 1: MỞ ĐẦU VÀ TỔNG QUAN DỰ ÁN

1.1. Giới thiệu chung

Trong bối cảnh ngành du lịch phát triển mạnh mẽ, các mô hình lưu trú như homestay và khách sạn nhỏ ngày càng phổ biến. Tuy nhiên, công tác quản lý tại nhiều cơ sở vẫn còn thực hiện thủ công, dẫn đến sai sót trong việc đặt phòng, tính toán hóa đơn và quản lý nhân sự. Xuất phát từ nhu cầu thực tế đó, nhóm thực hiện đề tài "Hệ thống quản lý Homestay (QLHOMESTAY)". Đây là một ứng dụng web được xây dựng nhằm hỗ trợ công tác quản lý tổng thể, cho phép đồng bộ thông tin về phòng, khách hàng, nhân viên, dịch vụ và hóa đơn. Hệ thống giúp tự động hóa quy trình vận hành, đảm bảo tính chuyên nghiệp và hiệu quả cao.

1.2. Mục tiêu và Phạm vi dự án

Mục tiêu chính của hệ thống là cung cấp một nền tảng web chạy trên môi trường Windows + IIS, sử dụng .NET và Entity Framework với cơ sở dữ liệu SQL Server. Hệ thống hướng tới hai nhóm đối tượng người dùng chính là Khách hàng và Nhân viên/Quản lý.

Phạm vi chức năng của hệ thống bao gồm các phân hệ chính: Quản lý danh mục (chức vụ, loại phòng), Quản lý phòng và tình trạng phòng, Quản lý khách hàng và lịch sử đặt phòng, Quản lý nhân viên và phân quyền, chức năng Đặt phòng (booking), Quản lý dịch vụ đi kèm, và xử lý Hóa đơn thanh toán.

CHƯƠNG 2: KẾ HOẠCH KIỂM THỬ

2.1. Định danh và Giới thiệu kế hoạch (Identifier & Introduction)

Kế hoạch kiểm thử này được định danh là TP-QLHOMESTAY-V1.0. Mục đích của tài liệu này là xác định chiến lược, phạm vi, tài nguyên và lịch trình cho hoạt động kiểm thử phần mềm QLHOMESTAY. Kế hoạch nhằm đảm bảo hệ thống đáp ứng đầy đủ các yêu cầu chức năng và phi chức năng đã được đề ra trong tài liệu đặc tả yêu cầu (SRS).

2.2. Các đối tượng kiểm thử (Test Items)

Dựa trên danh sách các luồng chức năng của dự án, các đối tượng cần kiểm thử bao gồm:

Module Khách hàng: Đăng ký, Đăng nhập, Tìm kiếm phòng theo ngày, Chọn phòng vào giỏ hàng, Xác nhận đặt phòng, Xem lịch sử phiếu đặt và hóa đơn, Gửi đánh giá.

Module Quản trị (Admin/Staff): Dashboard thống kê, Quản lý phòng (CRUD), Check-in, Check-out, Gọi dịch vụ, Gia hạn phòng, Đổi phòng, Quản lý nhân viên và khách hàng, Thống kê doanh thu.

Module Hệ thống: Tính năng tự động hủy phiếu đặt quá hạn, Tính toán giá phòng tự động, Quản lý phiên làm việc (Session).

2.3. Các tính năng không kiểm thử (Features Not To Be Tested)

Các tính năng thanh toán trực tuyến qua cổng thanh toán ngân hàng thật (do giới hạn môi trường kiểm thử, chỉ mô phỏng trạng thái thanh toán).

Khả năng chịu tải cực lớn (Stress Testing) vượt quá 10.000 người dùng đồng thời (do giới hạn phần cứng server kiểm thử).

Kiểm thử bảo mật chuyên sâu (Penetration Testing) ở mức độ hacker mũ trắng.

CHƯƠNG 2: KẾ HOẠCH KIỂM THỬ

2.4. Chiến lược và Phương pháp kiểm thử (Test Approach/Strategy)

Nhóm sẽ áp dụng phương pháp kiểm thử hộp đen (Black-box testing) kết hợp với kiểm thử giao diện người dùng (UI Testing).

Kiểm thử Đơn vị (Unit Testing): Thực hiện bởi developer trong quá trình viết code, tập trung vào các hàm xử lý logic như tính tổng tiền, kiểm tra ngày hợp lệ.

Kiểm thử Tích hợp (Integration Testing): Kiểm tra sự tương tác giữa các module, ví dụ: Khi "Gọi dịch vụ", hệ thống phải cập nhật bảng tblDichVuDaDat và trừ số lượng trong kho tblDichVu.

Kiểm thử Hệ thống (System Testing): Kiểm thử toàn bộ luồng nghiệp vụ từ đầu đến cuối (End-to-End), ví dụ: Khách tìm phòng -> Đặt phòng -> Nhân viên Check-in -> Gọi dịch vụ -> Check-out -> Xuất hóa đơn.

Kiểm thử Giao diện (UI/UX): Đảm bảo giao diện Responsive trên Desktop, Tablet và Mobile; kiểm tra các thông báo lỗi (Toast Notification) và xác nhận hành động (Modal).

2.5. Tiêu chí Đạt/Không đạt (Pass/Fail Criteria)

Tiêu chí Đạt (Pass): Chức năng hoạt động đúng theo logic mô tả trong SRS. Không có lỗi nghiêm trọng (Critical/High) gây crash ứng dụng hoặc sai lệch dữ liệu tài chính. Giao diện hiển thị đúng trên trình duyệt Chrome và Edge.

Tiêu chí Không đạt (Fail): Phát sinh lỗi ngoại lệ (Exception) chưa được xử lý, tính toán sai tổng tiền hóa đơn, hoặc dữ liệu không được lưu vào SQL Server.

2.6. Môi trường kiểm thử (Environmental Needs)

Phần cứng: Máy tính chạy hệ điều hành Windows.

Phần mềm máy chủ: IIS (Internet Information Services), SQL Server (cho cơ sở dữ liệu).

CHƯƠNG 2: KẾ HOẠCH KIỂM THỬ

Trình duyệt: Google Chrome (phiên bản mới nhất), Microsoft Edge.

Dữ liệu kiểm thử: Cơ sở dữ liệu mẫu bao gồm ít nhất 10 phòng, 5 loại phòng, 20 dịch vụ và 5 tài khoản nhân viên/khách hàng.

2.7. Phân công trách nhiệm (Roles and Responsibilities)

Đặng Quốc Hưng: Chịu trách nhiệm lập kế hoạch kiểm thử, thiết lập môi trường, kiểm thử các module Quản trị (Admin), và Quản lý cơ sở dữ liệu.

Trần Mỹ Duyên: Chịu trách nhiệm viết Test Case, thực hiện kiểm thử module Khách hàng (Client), kiểm thử giao diện (UI) và viết báo cáo lỗi.

CHƯƠNG 3: CHECKLIST

3.1. Rà soát Kiến trúc và Cơ sở dữ liệu

Dựa trên bảng checklist thiết kế, nhóm đã tiến hành rà soát cấu trúc cơ sở dữ liệu của QLHOMESTAY:

Tính toàn vẹn dữ liệu:

Bảng tblKhachHang: Khóa chính là ma_kh, đảm bảo tính duy nhất. Các trường sdt, cccd được kiểm tra ràng buộc không null.

Bảng tblHoaDon: Các trường tiền (tien_phong, tien_dich_vu) có ràng buộc check >= 0 để đảm bảo logic tài chính.

Bảng tblPhong: Ràng buộc khóa ngoại tham chiếu đến tblLoaiPhong và tblTinhTrangPhong được thiết lập chính xác để tránh dữ liệu rác.

Xử lý trạng thái:

Hệ thống quản lý trạng thái phòng rõ ràng: 1=Trống, 2=Đang sử dụng, 3=Đang dọn dẹp. Logic chuyển đổi trạng thái được thiết kế chặt chẽ trong các luồng Check-in/Check-out.

3.2. Rà soát Giao diện người dùng (UI Checklist)

Tính nhất quán: Font chữ mặc định là Arial, sử dụng bảng màu đồng nhất cho các trạng thái (Active, Hover, Disabled).

Phản hồi hệ thống:

Hệ thống có sử dụng Spinner/Progress Bar khi đang xử lý.

Các hành động quan trọng như "Hủy phiếu đặt" hoặc "Xóa nhân viên" đều có Modal xác nhận để ngăn chặn thao tác nhầm lẫn.

Validation (Kiểm tra đầu vào):

CHƯƠNG 3: CHECKLIST

Form Đăng ký: Kiểm tra định dạng Email (đuôi @gmail.com), SĐT (bắt đầu bằng 0, 9 số), CCCD (9 số).

Form Tìm phòng: Ngày đi (dateend) bắt buộc phải lớn hơn ngày đến (datestart).

CHƯƠNG 4: TEST CASES

4.1. Module Đăng ký và Đăng nhập

Test Case 01: Đăng ký tài khoản khách hàng thành công

Mục đích: Kiểm tra chức năng đăng ký với thông tin hợp lệ.

Dữ liệu đầu vào: MaKH="kh001", Pass="123456", SĐT="0901234567", Email="test@gmail.com".

Các bước thực hiện:

Truy cập trang Đăng ký.

Nhập đầy đủ thông tin hợp lệ vào form.

Nhấn nút "Đăng ký".

Kết quả mong đợi: Hệ thống thông báo "Đăng ký thành công", chuyển hướng về trang Đăng nhập, dữ liệu được lưu vào tblKhachHang.

Test Case 02: Đăng ký thất bại do trùng Mã khách hàng

Mục đích: Kiểm tra ràng buộc Unique của MaKH.

Dữ liệu đầu vào: MaKH đã tồn tại trong DB.

Kết quả mong đợi: Hệ thống báo lỗi "Tên tài khoản đã được sử dụng!".

Test Case 03: Đăng nhập Admin

Logic: Kiểm tra ma_nv và mat_khau trong tblNhanVien.

Kết quả mong đợi: Nếu đúng, chuyển vào trang Dashboard Admin. Nếu sai, báo "Login data is incorrect!".

4.2. Module Tìm kiếm và Đặt phòng (Client)

Test Case 04: Tìm kiếm phòng theo ngày hợp lệ

Dữ liệu: Ngày đến = Hôm nay, Ngày đi = Ngày mai.

CHƯƠNG 4: TESTCASE

Logic: Hệ thống lọc các phòng có ma_tinh_trang không thuộc (1,2) trong khoảng thời gian đó.

Kết quả: Hiện thị danh sách phòng trống kèm giá và hình ảnh.

Test Case 05: Đặt phòng Online

Điều kiện: Đã đăng nhập (Session["KH"] != null).

Hành động: Chọn phòng, nhấn "Đặt phòng".

Xử lý hệ thống: Tạo bản ghi trong tblPhieuDatPhong với ma_tinh_trang = 1 (Chờ xác nhận). Tự động gán giờ 12:00 PM cho ngày đến/đi.

4.3. Module Quản lý Vận hành (Admin)

Test Case 06: Thực hiện Nhận phòng (Check-in)

Mục đích: Chuyển đổi trạng thái phiếu đặt và phòng khi khách đến.

Hành động: Admin nhấn nút "Nhận phòng" trên chi tiết phiếu đặt.

Xử lý hệ thống:

Cập nhật tblPhieuDatPhong: ma_tinh_trang = 2 (Đã nhận phòng).

Cập nhật tblPhong: ma_tinh_trang = 2 (Đang sử dụng).

Tạo mới tblHoaDon với trạng thái "Chưa thanh toán".

Test Case 07: Gọi dịch vụ cho phòng

Dữ liệu: Chọn Dịch vụ A, Số lượng = 2.

Logic kiểm tra: Kiểm tra tồn kho (ton_kho). Nếu số lượng gọi $\leq$ tồn kho, cho phép gọi.

Xử lý hệ thống: Trừ tồn kho, thêm bản ghi vào tblDichVuDaDat, cập nhật tổng tiền dự tính.

Test Case 08: Thanh toán và Trả phòng (Check-out)

Logic tính toán: Tổng tiền = Tiền phòng + Tiền dịch vụ + Phụ thu.

CHƯƠNG 4: TESTCASE

Hành động: Nhấn "Check-out".

Kết quả:

tblHoaDon chuyển trạng thái sang "Đã thanh toán".

tblPhong chuyển sang trạng thái 3 (Đang dọn dẹp).

tblPhieuDatPhong chuyển sang Hoàn thành.

4.4. Module Báo cáo và Thống kê

Test Case 09: Thống kê doanh thu

Hành động: Chọn khoảng thời gian (Tháng này).

Kết quả: Biểu đồ hiển thị đúng tổng doanh thu từ các hóa đơn có trạng thái "Đã thanh toán", chi tiết doanh thu phòng và dịch vụ khớp với dữ liệu trong DB.

CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO

5.1. Tổng hợp lỗi phát hiện (Defect Report)

Trong quá trình kiểm thử, nhóm đã phát hiện và ghi nhận các lỗi sau:

Lỗi logic ngày tháng (Severity: High): Khi tìm kiếm phòng, nếu nhập ngày đi < ngày đến, hệ thống không báo lỗi mà trả về danh sách rỗng. -> Đã khắc phục bằng cách thêm Validation.

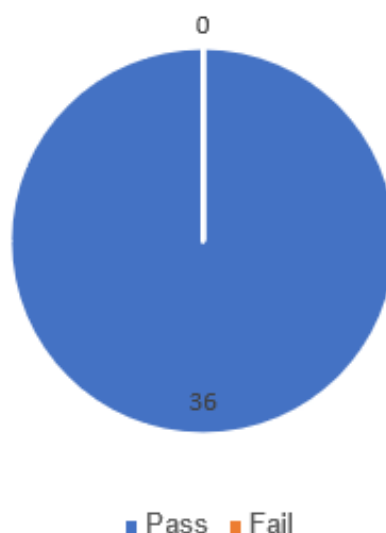
Lỗi giao diện (Severity: Low): Trên màn hình Mobile, nút "Đặt phòng" bị lệch khỏi khung hình. -> Đã khắc phục bằng CSS Media Query.

Lỗi dữ liệu (Severity: Medium): Cho phép nhập số lượng dịch vụ âm. -> Đã thêm ràng buộc check > 0 trong Database và Code.

Sau đây là thống kê kết quả Testcases theo biểu đồ tròn:

Đầu tiên là Testcases 1 – Đăng nhập tổng có 36 test case. Trong đó có 36 test case có kết quả là PASS và 0 test case có kết quả là FAIL.

Testcases 1 - Đăng nhập

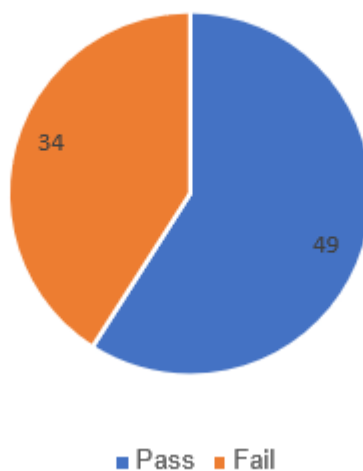


Hình 1. Biểu đồ tròn thể hiện kết quả của Testcases 1 – Đăng nhập

CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO

Tiếp theo là Testcases 2 – Đăng ký tổng có 83 test case. Trong đó có 49 test case có kết quả là PASS và 34 test case có kết quả là FAIL.

Testcases 2 - Đăng ký



Hình 2. Biểu đồ tròn thể hiện kết quả của Testcases 2 – Đăng ký

Tiếp theo là Testcases 3 – Đặt phòng tổng có 33 test case. Trong đó có 31 test case có kết quả là PASS và 2 test case có kết quả là FAIL.

Testcases 3 - Đặt phòng

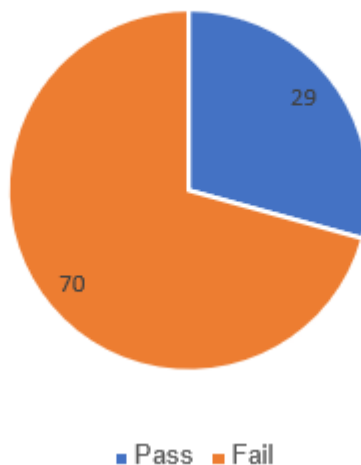


Hình 3. Biểu đồ tròn thể hiện kết quả của Testcases 3 – Đặt phòng

CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO

Tiếp theo là Testcases 4 – Sửa Thông tin cá nhân tổng có 99 test case. Trong đó có 29 test case có kết quả là PASS và 70 test case có kết quả là FAIL.

Testcases 4 - Sửa TT cá nhân



Hình 4. Biểu đồ tròn thể hiện kết quả của Testcases 4 – Sửa TT cá nhân

Cuối cùng là Testcases 5 – Đăng xuất tổng có 8 test case. Trong đó có 8 test case có kết quả là PASS và 0 test case có kết quả là FAIL.

Testcases 5 - Đăng xuất



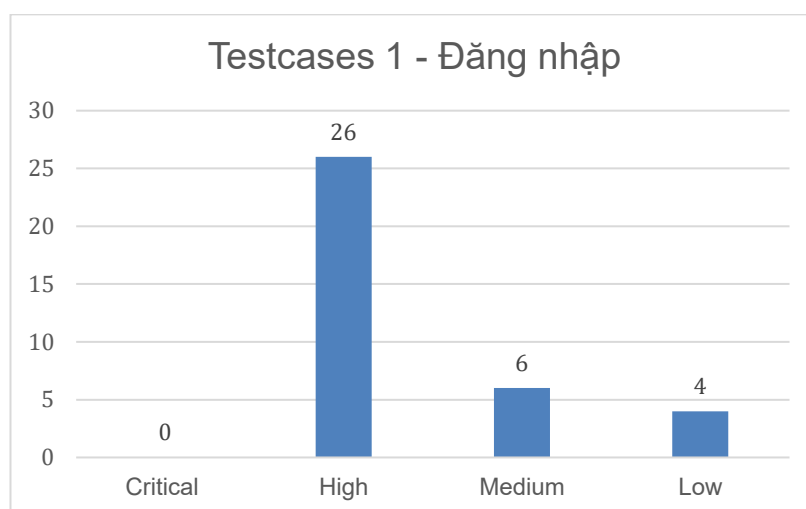
Hình 5. Biểu đồ tròn thể hiện kết quả của Testcases 5 – Đăng xuất

CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO

Thống kê kết quả của 5 biểu đồ trên cho thấy tổng số test case Chức năng bao gồm 259 test case. Trong đó có 153 (59%) test case có kết quả là PASS và 106 (41%) test case có kết quả là FAIL. Dựa vào kết quả trên cho thấy phần lớn test case FAIL là do lỗi xác thực thông tin của Chức năng Đăng ký hoặc Sửa thông tin cá nhân.

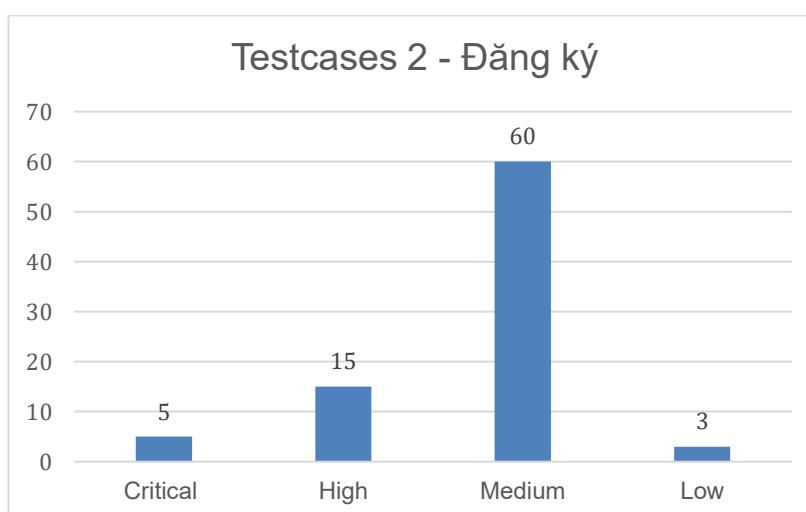
Dưới đây là các biểu đồ cột thể hiện các Lỗi theo Mức độ nghiêm trọng:

Đầu tiên là Testcases 1 – Đăng nhập có 0 lỗi Critical, 26 lỗi High, 6 lỗi Medium và 4 lỗi Low.



Hình 6. Biểu đồ cột của Testcase 1 thể hiện lỗi theo Mức độ nghiêm trọng

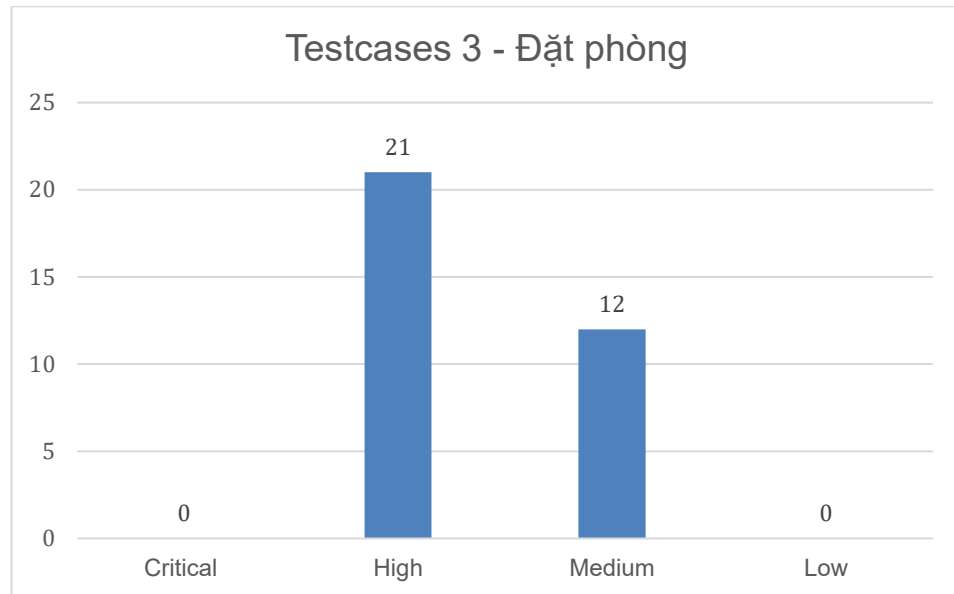
Tiếp theo là Testcases 2 – Đăng nhập có 5 lỗi Critical, 15 lỗi High, 60 lỗi Medium và 3 lỗi Low.



Hình 7 Biểu đồ cột của Testcase 2 thể hiện lỗi theo Mức độ nghiêm trọng

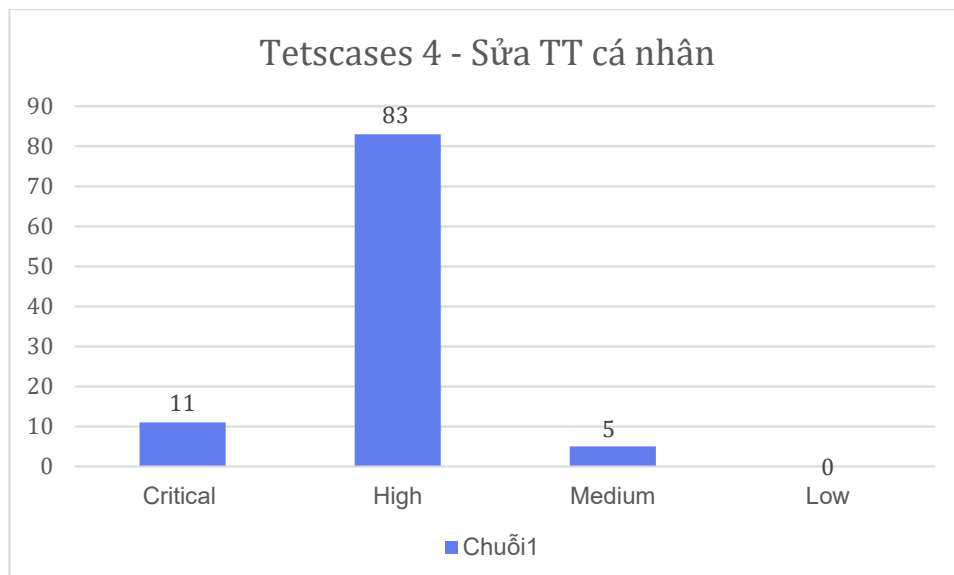
CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO

Tiếp theo là Testcases 3 – Đăng nhập có 0 lỗi Critical, 26 lỗi High, 6 lỗi Medium và 0 lỗi Low.



Hình 8. Biểu đồ cột của Testcase 3 thể hiện lỗi theo Mức độ nghiêm trọng

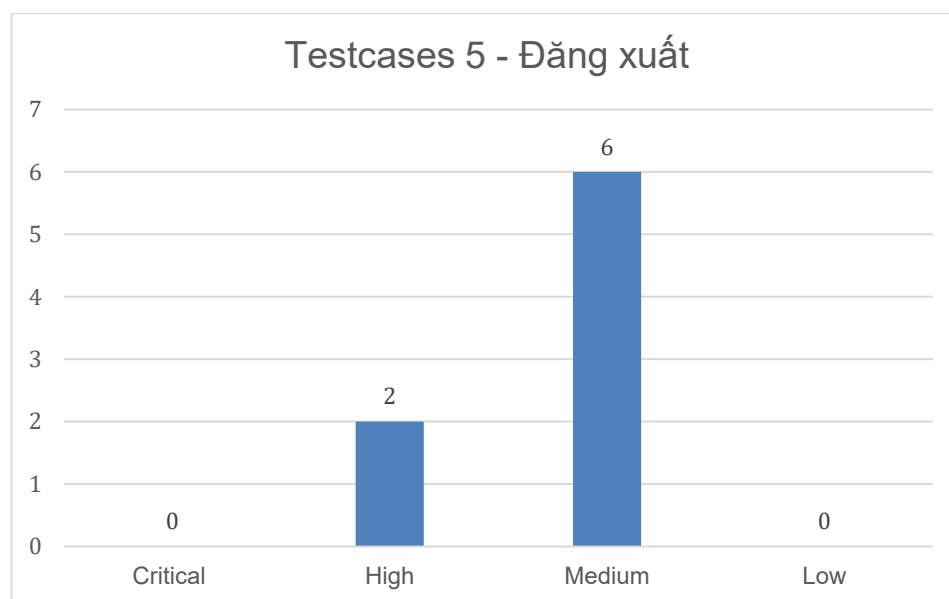
Tiếp theo là Testcases 4 – Đăng nhập có 11 lỗi Critical, 83 lỗi High, 5 lỗi Medium và 0 lỗi Low.



Hình 9. Biểu đồ cột của Testcase 4 thể hiện lỗi theo Mức độ nghiêm trọng

CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO

Cuối cùng là Testcases 5 – Đăng nhập có 0 lỗi Critical, 2 lỗi High, 6 lỗi Medium và 0 lỗi Low.



Hình 10. Biểu đồ cột của Testcase 5 thể hiện lỗi theo Mức độ nghiêm trọng

Dựa vào các biểu đồ cột Thống kê các lỗi theo mức độ nghiêm trọng ở trên cho thấy hầu hết các lỗi Critical rơi vào các chức năng như Đăng ký, Sửa thông tin cá nhân. Điều này cho thấy rằng ngoài các lỗi liên quan tới Nghiệp vụ Đặt phòng là nghiệp vụ chính trong dự án Kiểm thử lần này thì bên cạnh đó việc xác minh thông tin Đăng ký/ Sửa thông tin cá nhân cũng cần phải ràng buộc chặt chẽ hơn, tránh đi các lỗi căn bản mà thường không ai mắc phải, tuân thủ quy tắc liên quan tới xác thực thông tin.

5.2. Quản lý rủi ro và Kế hoạch dự phòng (Risks and Contingencies)

Dựa trên kết quả thực nghiệm với tỷ lệ lỗi (Fail Rate) lên tới 41% và sự tồn tại của nhiều lỗi nghiêm trọng (Critical Defects) liên quan đến tính toàn vẹn dữ liệu và bảo mật phiên, việc xây dựng một chiến lược quản lý rủi ro là bắt buộc trước khi xem xét đưa hệ thống vào vận hành. Mục này phân tích các rủi ro tiềm ẩn, đánh giá mức độ tác động và đề xuất các phương án đối phó cụ thể.

CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO

Đánh giá và Phân loại Rủi ro (Risk Assessment)

Nhóm kiểm thử sử dụng ma trận rủi ro (Risk Matrix) dựa trên hai yếu tố: Khả năng xảy ra (Probability) và Mức độ ảnh hưởng (Impact) để phân loại các rủi ro thành 3 cấp độ: Cao (High), Trung bình (Medium) và Thấp (Low).

A. Rủi ro Dữ liệu (Data Integrity Risks) - Mức độ: CAO (CRITICAL)

Đây là nhóm rủi ro nguy hiểm nhất hiện nay của hệ thống QLHOMESTAY.

Mô tả: Hệ thống hiện tại thiếu các ràng buộc duy nhất (Unique Constraints) đối với các trường thông tin định danh quan trọng như Số Căn cước công dân (CCCD), Email và Số điện thoại (như đã chứng minh qua Test Case TC_Register_040, TC_Register_041).

Hệ quả:

Khách hàng có thể tạo hàng loạt tài khoản ảo để trục lợi khuyến mãi hoặc phá hoại (spam booking).

Dữ liệu khách hàng bị phân mảnh, gây khó khăn cho việc tra cứu lịch sử lưu trú và chăm sóc khách hàng.

Sai lệch trong báo cáo thống kê doanh thu và nhân khẩu học.

B. Rủi ro Bảo mật và Riêng tư (Security & Privacy Risks) - Mức độ: CAO

Mô tả: Lỗi rò rỉ phiên làm việc (Session Leak) phát hiện tại TC_Booking_013 cho thấy hệ thống không xóa sạch dữ liệu tạm (Cache/Session) khi người dùng đăng xuất.

Hệ quả:

Trong môi trường công cộng (ví dụ: máy tính tại sảnh lễ tân), người dùng sau có thể vô tình nhìn thấy thông tin cá nhân, lịch trình hoặc đơn đặt phòng của người dùng trước.

Vi phạm nghiêm trọng các quy định về bảo mật thông tin cá nhân, làm mất uy tín của Homestay.

CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO

C. Rủi ro Vận hành và Nghiệp vụ (Operational Risks) - Mức độ: TRUNG BÌNH

Mô tả: Các lỗi về đồng bộ trạng thái (Ví dụ: Khách hủy phòng nhưng Admin vẫn thấy "Đã nhận" - TC_Booking_023) và thiếu validation chặt chẽ ở khâu "Sửa đổi thông tin".

Hệ quả:

Double Booking (Đặt trùng): Nhân viên lễ tân có thể giữ phòng cho một đơn đã hủy, trong khi từ chối khách hàng vắng lai mới đến, gây lãng phí công suất phòng (Vacancy Loss).

Dữ liệu rác: Việc cho phép nhập tên chứa ký tự đặc biệt hoặc toàn số (\$\$\$, 1234) gây thiếu chuyên nghiệp khi xuất hóa đơn hoặc in phiếu nhận phòng.

Kế hoạch Dự phòng và Biện pháp Giảm thiểu (Mitigation & Contingency Plan)

Đối với mỗi nhóm rủi ro đã xác định, nhóm đề xuất chiến lược "Phòng ngừa" (Preventive - thực hiện ngay để giảm xác suất) và "Ứng phó" (Corrective - thực hiện khi rủi ro xảy ra).

Rủi ro	Chiến lược Phòng ngừa (Trước khi Deploy)	Kế hoạch Ứng phó (Khi sự cố xảy ra)
Trùng lặp dữ liệu (Duplicate Data)	1. Cải tổ Database: Thêm ngay ràng buộc UNIQUE INDEX cho các cột CCCD, Email, SDT trong SQL Server.	1. Chạy Script làm sạch: Sử dụng câu lệnh SQL để quét và gộp (merge) các tài khoản trùng lặp định danh.

CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO

Rủi ro	Chiến lược Phòng ngừa (Trước khi Deploy)	Kế hoạch Ứng phó (Khi sự cố xảy ra)
	2. Backend Validation: Bổ sung hàm <code>CheckExist()</code> trong Controller trước khi thực hiện lệnh <code>Save()</code> .	2. Thông báo khách hàng: Liên hệ khách hàng để xác nhận tài khoản chính chủ và khóa các tài khoản phụ.
Rò rỉ Phiên (Session Leak)	1. Sửa lỗi Logout: Đảm bảo gọi <code>Session.Abandon()</code>, <code>Session.Clear()</code> và xóa Auth Cookie trong code. 2. Disable Cache: Cấu hình No-Cache cho các trang chứa thông tin nhạy cảm.	1. Force Logout: Admin thực hiện chức năng buộc đăng xuất toàn bộ người dùng (Reset AppPool). 2. Giảm Timeout: Giảm thời gian tồn tại của Session xuống còn 2-3 phút thay vì 5 phút.

CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO

Rủi ro	Chiến lược Phòng ngừa (Trước khi Deploy)	Kế hoạch Ứng phó (Khi sự cố xảy ra)
Sai lệch trạng thái (State Inconsistency)	1. Transaction Management: Sử dụng Database Transaction để đảm bảo tính nhất quán (ACID) khi cập nhật trạng thái giữa các bảng. 2. Real-time Refresh: Thêm cơ chế tự động tải lại trang (Auto-reload) cho trang Dashboard của Admin.	1. Đối soát thủ công: Nhân viên lễ tân phải gọi điện xác nhận với khách trước giờ Check-in 2 tiếng. 2. Quy trình giấy: Chuyển sang ghi chép sổ sách tạm thời nếu hệ thống báo cáo sai lệch quá nhiều.
Mất mát dữ liệu (Data Loss)	1. Cơ chế Sao lưu (Backup): Thiết lập lịch backup tự động hàng ngày (Daily Full Backup) và sao lưu log giao dịch hàng giờ (Hourly Transaction Log).	1. Phục hồi (Restore): Kích hoạt quy trình khôi phục dữ liệu từ bản backup gần nhất. 2. Hệ thống dự phòng: Chuẩn bị một server dự phòng

CHƯƠNG 5: BÁO CÁO KẾT QUẢ VÀ ĐÁNH GIÁ RỦI RO

Rủi ro	Chiến lược Phòng ngừa (Trước khi Deploy)	Kế hoạch Ứng phó (Khi sự cố xảy ra)
		(Failover server) để chuyển hướng truy cập.

Kiến nghị về Quy trình Phát triển để Giảm thiểu Rủi ro Tương lai

Để đảm bảo các rủi ro này không tái diễn trong các phiên bản cập nhật sau, nhóm kiến nghị áp dụng quy trình Kiểm soát Chất lượng (Quality Control) chặt chẽ hơn:

Áp dụng Kiểm thử Hồi quy (Regression Testing) Tự động: Hiện tại việc kiểm thử lại 325 Test Case tốn rất nhiều nhân lực. Cần xây dựng bộ script kiểm thử tự động (sử dụng Selenium hoặc Unit Test Framework) cho các luồng quan trọng như Đăng ký, Đặt phòng để chạy mỗi khi có code mới.

Thiết lập Code Review: Bắt buộc có bước review mã nguồn, đặc biệt là các logic liên quan đến Session và Database Query, để phát hiện sớm các lỗi hỏng logic như thiếu WHERE hoặc quên Session.Clear().

Kiểm thử Chấp nhận người dùng (UAT) nghiêm ngặt: Trước khi Go-live, cần tổ chức một đợt UAT với dữ liệu thật và người dùng thật (đóng vai lễ tân, khách hàng khó tính) để tìm ra các lỗi về trải nghiệm (UX) và quy trình thực tế mà Tester có thể bỏ sót.

Kết luận: Mặc dù hệ thống QLHOMESTAY tiềm ẩn nhiều rủi ro ở giai đoạn hiện tại, nhưng hầu hết đều là các rủi ro có thể kiểm soát và khắc phục được thông qua việc chuẩn hóa lại mã nguồn và cấu trúc cơ sở dữ liệu. Việc thực hiện nghiêm túc kế hoạch dự phòng nêu trên sẽ giúp giảm thiểu tối đa thiệt hại và nâng cao độ tin cậy của hệ thống.

KẾT LUẬN

Dựa trên kết quả thực thi 325 Test Case bao phủ các phân hệ chức năng chính của Hệ thống Quản lý Homestay (QLHOMESTAY), nhóm kiểm thử đưa ra kết luận cuối cùng và các phân tích định lượng về chất lượng phần mềm như sau.

Kết luận chung về chất lượng phần mềm

Căn cứ vào bộ tiêu chí chấp nhận sản phẩm (Acceptance Criteria) đã đề ra trong Kế hoạch kiểm thử, hệ thống QLHOMESTAY hiện tại được đánh giá là KHÔNG ĐẠT (FAIL) và CHƯA ĐỦ ĐIỀU KIỆN ĐỂ TRIỂN KHAI (NOT READY FOR DEPLOYMENT).

Quyết định này dựa trên tỷ lệ lỗi nghiêm trọng (Critical/High Severity) vượt quá ngưỡng cho phép (tổng cộng 16 lỗi Critical và 147 lỗi High), cùng với sự vi phạm các nguyên tắc căn bản nhất trong thiết kế phần mềm quản lý dữ liệu. Mặc dù hệ thống đáp ứng được các luồng đi cơ bản (Happy Path) như đăng nhập hay xem phòng, nhưng lại sụp đổ hoàn toàn khi gặp các kịch bản dữ liệu thực tế, đặc biệt là trong khâu xác thực và bảo vệ tính toàn vẹn dữ liệu.

Phân tích các nguyên nhân trọng yếu dẫn đến đánh giá "Không Đạt"

Sự thất bại của phiên bản phần mềm hiện tại không đến từ sự thiếu hụt tính năng, mà đến từ sự lỏng lẻo, thiếu chặt chẽ trong việc xây dựng nền móng xử lý dữ liệu. Dưới đây là 3 nhóm nguyên nhân cốt lõi:

A. Sự sụp đổ của cơ chế Xác thực dữ liệu (Validation Failure)

Hệ thống thể hiện sự thiếu nhất quán nghiêm trọng trong việc áp dụng các quy tắc kiểm tra dữ liệu đầu vào (Input Validation).

Tiêu chuẩn kép giữa "Thêm mới" và "Cập nhật": Trong khi chức năng Đăng ký (Create) có thực hiện một số kiểm tra cơ bản, thì chức năng Cập nhật hồ sơ (Update) lại mở cửa hoàn toàn cho dữ liệu rác. Việc hệ thống cho phép người dùng xóa bỏ mật khẩu, hoặc nhập các ký tự đặc biệt (\$\$\$, @@@) vào trường Tên và Địa chỉ khi sửa

hồ sơ là minh chứng cho việc logic Validation không được tái sử dụng hoặc thiết kế đồng bộ ở tầng Backend.

Thiếu Validation phía Server (Server-side Validation): Hầu hết các lỗi định dạng (như nhập chữ vào số điện thoại, nhập sai độ dài CCCD) chỉ được bắt hời hợt hoặc bị bỏ qua. Điều này cho thấy hệ thống đang phụ thuộc quá nhiều vào Validation ở giao diện (Frontend) hoặc hoàn toàn không có lớp phòng vệ này. Trong kỹ thuật phần mềm, việc thiếu Server-side validation là một lỗi sơ đẳng, tạo điều kiện cho việc tiêm nhiễm dữ liệu bẩn vào cơ sở dữ liệu.

B. Vi phạm nghiêm trọng tính Duy nhất và Toàn vẹn dữ liệu (Data Integrity Violation)

Đối với một hệ thống đặt phòng (Booking System), dữ liệu định danh khách hàng (Số điện thoại, Email, Căn cước công dân) là tài sản quan trọng nhất. Tuy nhiên, kết quả kiểm thử cho thấy hệ thống đã thất bại trong việc bảo vệ tài sản này:

Trùng lặp dữ liệu định danh (Duplicate Identity): Việc hệ thống cho phép tạo nhiều tài khoản với cùng một số CCCD (091205008887) hoặc cùng một Email là lỗi nghiêm trọng nhất (Critical Bug).

Hệ quả nghiệp vụ: Khi một khách hàng đến check-in, lễ tân sẽ không thể xác định được đâu là tài khoản chính chủ. Lịch sử đặt phòng sẽ bị phân tán trên nhiều tài khoản rác khác nhau.

Rủi ro pháp lý: Việc lưu trữ trùng lặp CCCD gây khó khăn cho việc báo cáo tạm trú/tạm vắng với cơ quan chức năng, đồng thời tiềm ẩn rủi ro gian lận thương mại (một người hưởng khuyến mãi nhiều lần).

Nguyên nhân kỹ thuật: Lỗi này chỉ ra rằng Cơ sở dữ liệu (Database Schema) đang thiếu các ràng buộc UNIQUE CONSTRAINT trên các cột quan trọng, và tầng ứng dụng (Controller) thiếu hoàn toàn logic kiểm tra sự tồn tại (CheckExisting) trước khi ghi dữ liệu.

C. Lỗi hỏng trong quản lý Phiên làm việc và Bảo mật (Security & Session Management)

Ngoài các lỗi về dữ liệu, hệ thống còn tồn tại lỗi bảo mật ảnh hưởng trực tiếp đến quyền riêng tư của khách hàng:

Rò rỉ phiên (Session Leakage): Lỗi người dùng B nhìn thấy giỏ hàng/phiếu đặt phòng của người dùng A sau khi A đăng xuất là không thể chấp nhận được. Điều này cho thấy cơ chế quản lý Session/Cookie của hệ thống đang hoạt động sai lệch, không xóa sạch (Clear/Abandon) dữ liệu tạm khi kết thúc phiên.

Rủi ro: Trong môi trường Homestay, nơi nhiều khách có thể dùng chung máy tính công cộng tại sảnh lễ tân để đặt dịch vụ, lỗi này sẽ dẫn đến việc lộ thông tin cá nhân và lịch trình di chuyển của khách hàng trước đó.

Đánh giá tác động nghiệp vụ (Business Impact Analysis)

Nếu hệ thống này được đưa vào vận hành thực tế (Go-live) với trạng thái hiện tại, chủ Homestay sẽ đối mặt với các rủi ro sau:

Mất uy tín thương hiệu: Khách hàng sẽ mất niềm tin khi thấy thông tin cá nhân của mình bị sai lệch, hoặc hệ thống cho phép nhập liệu cầu thả (như tên toàn số hoặc ký tự lạ).

Thiệt hại tài chính: Lỗi logic trạng thái (Khách hủy phòng nhưng Admin vẫn thấy "Đã nhận") sẽ dẫn đến việc giữ phòng ảo, từ chối khách mới, gây lãng phí công suất phòng (Vacancy loss).

Chi phí sửa chữa (Maintenance Cost): Theo quy tắc 1-10-100 trong kiểm thử phần mềm, chi phí để sửa các lỗi dữ liệu trùng lặp khi hệ thống đã có dữ liệu thật sẽ tốn kém gấp 100 lần so với việc sửa ngay tại giai đoạn này (do phải thực hiện Data Cleaning và Migration).

Kiến nghị và Điều kiện tiên quyết để nghiệm thu lại

Dựa trên các phân tích trên, nhóm kiểm thử đề xuất TỪ CHỐI NGHIỆM THU phiên bản hiện tại và yêu cầu đội ngũ phát triển thực hiện các biện pháp khắc phục bắt buộc sau đây (Mandatory Fixes):

Quy hoạch lại Cơ sở dữ liệu (Database Refactoring):

Thêm ngay ràng buộc UNIQUE cho các trường: CCCD, SoDienThoai, Email trong bảng KháchHang và NhanVien.

Rà soát lại các ràng buộc độ dài (LEN) và kiểu dữ liệu để đảm bảo khớp với đặc tả (ví dụ: SĐT phải là 10 số).

Gia cố tầng Validation (Backend Validation):

Viết lại toàn bộ logic Validation trong Controller cho cả hai luồng Đăng ký và Cập nhật hồ sơ.

Sử dụng Data Annotations hoặc Fluent Validation trong .NET để đảm bảo mọi dữ liệu đầu vào đều được kiểm tra chặt chẽ (No empty, Regex for Phone/Email, No special chars for Name).

Thực hiện hàm Trim() (cắt khoảng trắng) cho tất cả các trường nhập liệu dạng chuỗi trước khi lưu.

Sửa lỗi Bảo mật Session:

Viết lại quy trình Đăng xuất (Logout): Đảm bảo gọi lệnh Session.Abandon(), xóa AuthCookie và xóa sạch các biến session cục bộ (như Cart, BookingData).

Thực hiện Kiểm thử hồi quy (Regression Testing):

Sau khi sửa lỗi, bắt buộc phải chạy lại toàn bộ 325 Test Case để đảm bảo việc sửa lỗi không sinh ra lỗi mới (Side effects).

Chỉ khi nào các lỗi loại Critical và High được khắc phục triệt để và tỷ lệ Pass đạt tối thiểu 95%, hệ thống mới được xem xét để chuyển sang giai đoạn Kiểm thử chấp nhận người dùng (UAT). Báo cáo này đóng vai trò là rào chắn chất lượng

(Quality Gate), ngăn chặn việc phát hành một sản phẩm phần mềm chưa hoàn thiện ra thị trường.